Job Scout.

Job Scout: threat model

VERSION 0.12 · 19 OCTOBER 2026 · REVIEWED AT EVERY SPRINT CLOSE AND AFTER EVERY RED TEAM

A threat model sets out what needs protecting, who or what might cause harm, where they can get in, and what stops them. The red team tests this model every quarter; the risk register tracks the resulting risks and their owners. Terms are explained in the glossary.

1. What needs protecting

ASSET	WHY IT MATTERS
The user's mailbox	Private correspondence, including other people's personal data
The mail password	Full access to the mailbox
The user's career record and previous documents	Personal history; the basis of every claim made in their name
Their reputation with employers	An application that overstates, or a message sent without their knowledge, cannot be withdrawn
The board	Their private record of applications, replies and decisions
The rules and settings	They steer every judgement the system makes
The PC	It runs the code, holds the files and is reachable by the cloud tasks through the file bridge

2. Who or what might cause harm

SOURCE	EXAMPLE	MOTIVE
A stranger writing an advert or alert	Hidden text telling AI screeners to score the role highly	Gaming automated screening, usually aimed at many systems, not this one
A fraudster	A fake recruiter or a fake "offer" asking for bank details or a payment	Money or personal data
A malicious web page	Content written to steer the reader or to leak data	Data theft
The AI itself, by mistake	An invented claim, a wrong score, a misread reply	No motive: errors in judgement
A change by a supplier	Ollama updating the local model; Anthropic updating Claude; a site changing its email layout	No motive: silent changes in behaviour
The user, by mistake	A setting that filters out good roles	No motive

3. Trust boundaries and entry points

Text from strangers enters at three points, marked "untrusted text" on the technical architecture diagram:

1. **Alert emails**, read by code on the PC through Proton Mail Bridge.
2. **Adverts**, downloaded by code on the PC and read by the local model; or read in the cloud by part 2 when the PC could not.
3. **Web search results**, read by the finder in the cloud.

Replies to applications enter with the alert emails (1). The boundaries that contain them:

BOUNDARY	WHAT CROSSES IT	WHAT MAY NOT
Mailbox to PC code	Emails, read-only	Any command that changes or sends mail

BOUNDARY	WHAT CROSSES IT	WHAT MAY NOT
PC code to local model	One cleaned advert or reply at a time	Tools, files, internet access
PC to cloud	Cleaned role records, checked job facts, reply summaries	Raw emails, sender addresses, the password, the private store
Cloud to PC	Files written into the two shared folders, checked first	Commands; the private store
Cloud to board	Draft cards, checked reply patches, Inbox entries	The settings document; other cards, except checked reply patches

4. Threats and controls

#	THREAT	ENTRY	CONTROLS	TESTED BY
T1	Prompt injection steers a score or a draft	1, 2, 3	Code removes instruction-like lines from every field and reports them; text held between markers as data; outputs checked by code	RT1, RT2, RT9, RT10
T2	Injection steers the local reader	2	No tools; fixed answer format; grounding keeps only facts in the advert's own words	RT7
T3	An input asks for data to be sent out	1, 2	No agent has a sending tool; request removed and reported	RT3
T4	A fake recruiter or phishing reply is trusted	1	Sender judged by address and DKIM, not display name; links never opened; requests quoted, never acted on; warnings carried to the board	RT5, RT8
T5	An oversized or malformed input breaks a step	1, 2	Field length caps; parsers tested on hostile fixtures; a failed fetch marks nothing as read	RT6
T6	A contradictory or misleading advert produces a bad score	2	Scorer told to flag contradictions; the user reviews every shortlisted role	RT4
T7	A draft claims more than the user's record supports	AI error	Barred claims fail the build; independent reviewer with code-checked quotes; the user signs off	Reviewer cases 09 to 16
T8	The system acts for the user (applies, replies, accepts)	AI error or T1	No tool can send; instructions forbid it; cards are drafts; moves are suggestions until earned	RT8; procedure review at every sprint close
T9	The password or private store is read	Any	Encrypted for the local Windows account, outside both shared folders; never listed or staged	Procedure review
T10	Strangers' personal data kept or exposed	1	Raw emails stay in the private store for 30 days; summaries only to the cloud; no contact details on cards; 90-day retention	Retention and card tests
T11	Silent model change alters behaviour	Supplier	Local model digest checked daily; evaluations before any change; model recorded in the ledger	`npm run eval:reader`
T12	A setting is changed badly or by an AI	The user or AI	Settings checked on entry and logged; no AI can write them; code falls back to defaults on a bad value	Board tests

5. Residual risks

- The cloud tasks can reach both shared folders in full, because the packs and the vault need them. Their reach is limited by instructions and checks, not by permissions.
- The reviewer's read-only tools depend on the scheduled task loading its agent definition (G6).
- The Claude model is not pinned. A change is recorded, but not blocked.
- Defences are tested quarterly with ten cases. New kinds of attack may need new cases.

6. Findings so far

The first full red team (17 October 2026) held all ten cases. It found four bugs, each recorded in the backlog: BUG-1 (subject line not cleaned, fixed), BUG-2 (cloud could not reach test outputs, fixed), BUG-3 (reply warnings lost on the board, Sprint 8) and BUG-4 (calendar time zone read as the meeting time, fixed). Full report: docs\redteam\2026-10-17.md.